



PROS-NC-007

PROCEDIMIENTO GESTIÓN DE INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN

Sistema de Gestión de Seguridad de la Información – Nivel Central

Versión Oficial Actual v07 – Noviembre del 2024

	Responsable	Fecha	Firma
Elaborado	Pablo Fajardo	20.11.2024	
Revisado	Jose C/la	20.11.2024	
Aprobado	Jorge Herrera	20.11.2024	

Documentos de control y sellos:

- Sello circular del Ministerio de Salud, Encargado de Seguridad de la Información y Ciberseguridad, con una estrella en la parte inferior.
- Sello circular del Departamento de Tecnología de la Información y Comunicaciones, Gabinete de Ministros.

PROCEDIMIENTO DE GESTIÓN DE INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN

Sistema de Gestión de Seguridad de la Información – Nivel Central

MINISTERIO DE SALUD

ID: PROS - NC- 07

Versión: 7

Página 2 de 28

TLP: BLANCO

CONTENIDO

1	PROPÓSITO.....	3
2	ALCANCE.....	3
3	TERMINOLOGÍA.....	4
4	MARCO NORMATIVO Y DOCUMENTOS RELACIONADOS	5
5	ROLES Y RESPONSABILIDADES.....	7
6	PROCEDIMIENTO.....	9
6.1	Notificación de un incidente de seguridad	9
6.2	Gestión de Incidentes.....	9
6.3	Reporte de eventos y debilidades en la Seguridad de la Información	10
6.4	Procedimiento para gestión de Incidentes.	12
6.5	Equipo de respuesta a incidentes y Comité de Crisis	18
6.6	Declaración del Nivel de crisis y equipo responsable según el nivel de criticidad (Impacto y Urgencia):.....	20
6.7	Proceso Disciplinario	21
6.8	Continuidad de la Seguridad de la Información	22
6.9	Recolección de evidencia.....	22
6.10	Comunicación a los involucrados.....	23
6.11	Análisis de causa y cierre del incidente	23
6.12	Aprender de los incidentes en la seguridad de la información	23
7	PLAZOS DE NOTIFICACIÓN DE INCIDENTES DE SEGURIDAD	24
8	REGISTROS.....	24
9	DIFUSION.....	24
10	PERÍODO DE REVISIÓN.	25
11	EXCEPCIONES AL CUMPLIMIENTO DE LA POLÍTICA.....	25
12	CONTROL DE VERSIONES.....	25
13	ANEXOS.....	27



PROCEDIMIENTO DE GESTIÓN DE INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN

Sistema de Gestión de Seguridad de la Información - Nivel Central

MINISTERIO DE SALUD

ID: PROS - NC- 07

Versión: 7

Página 3 de 28

TLP: BLANCO

1 PROPÓSITO.

Establecer las actividades necesarias en la Subsecretarías de Salud Pública y Redes Asistenciales, para la detección oportuna y tratamiento de vulnerabilidades o eventos que comprometan la seguridad de los Activos de Información de la Institución.

Establecer responsabilidades de las distintas Unidades con relación a la seguridad de los datos institucionales (integridad, disponibilidad y confidencialidad), ya sea se encuentren en la plataforma informática como en su manipulación a cargo de los funcionarios en general.

Responder en forma rápida, eficaz y ordenada ante la ocurrencia de incidentes de seguridad que afecten los activos de información institucionales.

Asegurar un enfoque consistente y eficaz sobre la gestión de los incidentes de seguridad de la información, incluida la comunicación sobre eventos de seguridad y debilidades.

2 ALCANCE.

Este procedimiento aborda la gestión de incidentes de seguridad que afecten a los activos de información del tipo: base de datos, documento, equipo, expediente, formulario, infraestructura física, persona, sistema de información, software, en cuanto a la:

- Confidencialidad: acceso no autorizado a la información.
- Integridad: Modificación no autorizada, destrucción o pérdida de información.
- Disponibilidad: Inaccesibilidad a la información.

Este procedimiento es aplicable a todos los funcionarios¹ (planta, contrata, reemplazos y suplencia), personal a honorarios y terceros (proveedores, compra de servicios, etc.), que presten servicios para las Subsecretarías de Salud Pública y de Redes Asistenciales y que tengan derechos de acceso a la información que puedan afectar los activos de información del Ministerio de Salud.

En cuanto a las temáticas de protección abordadas, el ámbito de aplicación de esta política corresponde al (a los) Dominio(s) de Seguridad de la Información y Controles de Seguridad respectivos, detallados a continuación:

Alcance de Dominios y Controles de Seguridad de la Información		
Estándar	ID Control	Nombre del Control
ISO 27001:2022	A 05.5	Contacto con las autoridades
	A 05.6	Contacto con grupos de interés especial
	A 06.8	Notificación de los eventos de seguridad de la información

¹ A lo largo del procedimiento cada vez que se mencione funcionario se refiere a: funcionarios (planta, contrata, reemplazos y suplencia), personal a honorarios y terceros (proveedores, compra de servicios, etc.).



Alcance de Dominios y Controles de Seguridad de la Información

A 06.8	Notificación de puntos débiles de la seguridad
A 05.09	Inventario de información y otros activos asociados
A 05.13	Etiquetado de la información
A 05.24	Responsabilidades y procedimientos
A 05.26	Respuesta a incidentes de seguridad de la información
A 05.27	Aprendizaje de los incidentes de seguridad de la información
A 05.28	Recopilación de evidencias

3 TERMINOLOGÍA.

- **Amenaza:** Potencial causa de un incidente que podría dañar la organización o sus activos de información. Las amenazas pueden ser internas o externas, intencionales o accidentales.
- **Ciberataque:** Actividad intencional realizada por actores internos o externos que busca explotar vulnerabilidades para acceder, modificar, interrumpir o destruir información, sistemas o servicios.
- **Clasificación de Incidentes:** Proceso de evaluación del incidente para determinar su severidad y priorización, utilizando criterios como impacto operativo, alcance, activos afectados y probabilidad de recurrencia.
- **CSIRT:** Grupo designado responsable de coordinar y ejecutar las actividades de respuesta a incidentes, compuesto por especialistas en seguridad, TI y, según corresponda, representantes.
- **Evento de Seguridad:** Ocurrencia identificada de un sistema, servicio o estado de red que indica un posible incumplimiento de la política de seguridad de la información o falla de los controles o una situación desconocida que puede ser relevante para la seguridad.
- **Gestión de Incidentes:** Proceso estructurado para identificar, analizar, responder y aprender de los incidentes de seguridad con el objetivo de minimizar daños y prevenir su recurrencia.
- **Incidente de Seguridad:** Un evento o una serie de eventos de seguridad de la información no deseados o inesperados que tienen una probabilidad significativa de comprometer las operaciones institucionales y amenazar la seguridad de la información.
- **Lecciones Aprendidas:** Análisis posterior a un incidente que identifica oportunidades técnicas o administrativas de mejora en los procesos, controles y respuesta para prevenir futuros incidentes o mejorar la gestión.
- **Notificación de Incidentes:** Proceso formal de comunicar a las partes interesadas internas y externas sobre la ocurrencia de un incidente, su impacto y las medidas de mitigación implementadas, conforme a los requisitos legales y contractuales.



- **Recuperación:** Etapa del proceso de gestión de incidentes enfocada en restaurar las operaciones normales de los sistemas y servicios afectados, garantizando la seguridad y estabilidad.
- **Registro de Incidentes:** Documento o sistema utilizado para registrar, rastrear y gestionar incidentes de seguridad, incluyendo detalles como la naturaleza del incidente, su clasificación, impacto y acciones tomadas.
- **Resiliencia Cibernética:** Capacidad de los sistemas y servicios de la organización para resistir, recuperarse y adaptarse frente a incidentes de seguridad, minimizando el impacto en las operaciones.
- **Respuesta a Incidentes:** Conjunto de acciones específicas ejecutadas para contener, mitigar, investigar y resolver un incidente de seguridad, asegurando la continuidad de negocio.
- **Riesgo de Seguridad:** Combinación de la probabilidad de que ocurra un incidente y las consecuencias negativas asociadas.
- **Vulnerabilidad:** Debilidad en un sistema, proceso o configuración que puede ser explotada para comprometer la seguridad de la información o los sistemas.

4 MARCO NORMATIVO Y DOCUMENTOS RELACIONADOS.

- **Marco Normativo.**

- NCh ISO27001:2022: Seguridad de la información, ciberseguridad y protección de la privacidad - Controles de seguridad de la información.
- El Marco Jurídico referido a los Sistemas de Seguridad de la Información (SSI), publicado en el portal del CSIRT del Ministerio del Interior.
 - Decretos Supremos y Normas Internacionales de Seguridad de la Información y Ciberseguridad.
 - **Normas relacionadas:**
 - Ley N° 18.845, de 1989, que establece sistema de microcopia o micrograbación de documentos.
 - Ley N° 19.799, sobre documentos y firmas electrónicas
 - Ley N° 19.880 de bases de los procedimientos administrativos que rigen los actos de los órganos de la administración del Estado.
 - Ley N° 20.217, que modifica el Código de Procedimiento Civil y la ley N° 19.799, sobre documento electrónico, firma electrónica y los servicios de certificación de dichas firmas.
 - Ley N° 20.584, de derechos y deberes de los pacientes frente a las acciones y prestaciones de salud.
 - Ley N° 21.180 Ley de Transformación Digital del Estado, establece directrices para la modernización de los procesos y servicios digitales en instituciones públicas



Tiene implicaciones en la privacidad y la protección de datos personales, ya que establece estándares para la seguridad de la información en servicios y plataformas digitales, fomentando la eficiencia sin comprometer la confidencialidad y la integridad de los datos de los ciudadanos.

- Ley N° 21.663 sobre Marco de Ciberseguridad, esta ley proporciona un marco para asegurar la ciberseguridad de infraestructuras críticas, que indirectamente impacta en la protección de datos.
- Ley 21.668 establece la interoperabilidad de las fichas clínicas, sobre protección de datos establece un marco legal para salvaguardar la privacidad y los derechos de los ciudadanos en relación con sus datos personales.
- Decreto N° 181, de 2002, del Ministerio de Economía, Fomento y Reconstrucción, Subsecretaría de economía, que aprueba el Reglamento de la ley N° 19799 sobre documentos electrónicos, firma electrónica y la certificación de dicha firma.
- Decreto N° 14, de 2014, del Ministerio de Economía, Fomento y Turismo, Subsecretaría de Economía y empresas de menor tamaño, que modifica el decreto N° 181, de 2002, que aprueba Reglamento de la ley N° 19.799 sobre documentos electrónicos, firma electrónica y la certificación de dicha firma y deroga los decretos que indica.
- DFL N° 1, de 15 de marzo de 2021, del Ministerio de las Culturas, las artes y el patrimonio, que determina los requisitos del método de elaboración, conservación y uso de las microformas y de aquellos a emplear en la destrucción de documentos originales en virtud de la ley N° 18.845.
- Decreto N° 23, de 21 de octubre de 2021, que aprueba el reglamento que establece los medios y procedimientos técnicos y administrativos que se utilizarán en la generación de microformas.
- DFL N° 1, 2005, Ministerio de Salud.
- Decreto N° 41, de 2012, del Ministerio de Salud, Reglamento de ficha clínica.
- DFL N° 725, de 31 de enero de 1968, Código Sanitario.
- Decreto 273, de 2022, que establece la obligación de reportar incidentes de ciberseguridad a los organismos del Estado al CSIRT de gobierno.
- El Decreto N° 533 establece el marco regulatorio en ciberseguridad para las instituciones públicas en Chile, que incluye normas para la protección de la información, la gestión de incidentes de ciberseguridad y la protección de infraestructuras críticas, en las que se procesan datos personales.
- El Decreto Supremo N° 7 establece una Norma Técnica de Seguridad de la Información y Ciberseguridad, en concordancia con la Ley N° 21.180 sobre Transformación Digital del Estado. Que tiene el objetivo de definir estándares mínimos de seguridad y ciberseguridad para todos los órganos de la administración pública en Chile, contribuyendo a la protección de los datos personales y a la seguridad de la información en los sistemas digitales





gubernamentales.

▪ **Documentos Relacionados.**

- Documento del Sistema de Gestión de Seguridad de la Información, disponibles en isalud.minsal.cl.

5 ROLES Y RESPONSABILIDADES.

▪ **Funcionarios.**

- Manejar, utilizar y proteger el acceso a los documentos institucionales, asegurando su integridad, disponibilidad y confidencialidad en los procesos y sistemas institucionales.
- Informar de manera oportuna cualquier evento, debilidad o sospecha de incidente de seguridad que pueda comprometer la información institucional, a través de los canales oficiales establecidos por el MINSAL.

▪ **Encargado de Seguridad de la información y Ciberseguridad.**

- Diseñar, actualizar y garantizar el cumplimiento del procedimiento de gestión de incidentes.
- Supervisar la implementación de acciones correctivas y preventivas.
- Actuar como enlace principal entre la alta dirección, partes interesadas internas y externas, y otras áreas relevantes.
- Informar a la alta dirección sobre incidentes críticos y coordinar respuestas estratégicas.
- Gestionar y priorizar eventos e incidentes, liderando la ejecución de medidas para mitigar riesgos y prevenir recurrencias.
- Encargado de Informar a CSIRT de Gobierno, Incidentes de Seguridad de acuerdo con lo indicado en Decreto 273, de 2022 y Ley N° 21.180.

▪ **Departamento de Tecnologías.**

- Proporcionar soporte técnico en la gestión de incidentes que afecten los sistemas y la infraestructura tecnológica de su administración.
- Identificar y remediar vulnerabilidades explotadas en incidentes.
- Proporcionar logs, configuraciones y otros datos técnicos para el análisis de los incidentes.
- Coordinar a las unidades internas de Infraestructura, Operaciones y Desarrollo de Sistemas, Seguridad.
- Implementar medidas de recuperación y restauración de servicios afectados.

▪ **Unidades responsables de los datos.**

- Dar cumplimiento a las políticas de seguridad de la información, aplicar el presente procedimiento y gestionar los incidentes en lo que se refiere al uso, manipulación y



protección de acceso a datos institucionales de modo de garantizar su integridad, disponibilidad y confidencialidad.

- o Representar los intereses de las áreas afectadas y colaborar en la gestión del impacto de los incidentes en los procesos de unidades responsables.
- o Informar sobre incidentes detectados en sus áreas.
- o Apoyar en la evaluación del impacto del incidente en sus procesos.
- o Implementar las recomendaciones para mitigar riesgos futuros en su ámbito.

▪ **Equipo de Respuesta de Incidentes.**

- o Supervisar que los Equipos o Áreas Resolutoras gestionen los incidentes de manera adecuada y conforme a su nivel de criticidad.
- o Gestionar los incidentes de acuerdo con el nivel de criticidad.
- o Coordinar la respuesta a incidentes de alto impacto con apoyo de las siguientes áreas:
 - ✓ Infraestructura física.
 - ✓ Operaciones TIC.
 - ✓ Recursos Humanos.
 - ✓ Unidad Jurídica.
 - ✓ Servicios Generales o División de Administración.
 - ✓ Unidades responsables de los datos afectados.

▪ **Equipos o Áreas resolutoras designadas para la gestión de incidentes.**

- o Será responsable de:
 - ✓ Coordinar la activación de los equipos de respuesta ante incidentes.
 - ✓ Identificar la causa raíz de los incidentes y proponer medidas correctivas.
 - ✓ Generar y mantener reportes documentados sobre la gestión de incidentes.
 - ✓ Realizar el seguimiento de las medidas de mitigación hasta su cierre.
 - ✓ Mantener comunicación activa con CSIRT de Gobierno u organismos relevantes para la gestión de incidentes.

Nota: El personal designado deberá contar con un respaldo que lo reemplace en caso de ausencia.

Todos los usuarios, Administradores de Seguridad, Custodio de las Datos, las Unidades de Informática, Jefes de Servicio, Directores, Jefes de División, Jefes de Departamento y Gestión de Personas son responsables del cumplimiento de este procedimiento.



6 PROCEDIMIENTO.

6.1 Notificación de un incidente de seguridad.

Todo el personal, incluidos funcionarios, personal a honorarios y terceros, debe informar de manera inmediata cualquier debilidad, evento, incidente, amenaza o riesgo que pueda comprometer la seguridad de los activos de la organización. Para ello, el MINSAL dispone de los siguientes canales de comunicación únicos:

- **Contacto Telefónico:**
 - +(562) 800 123 573
- **Correo Electrónico:**
 - Temas técnicos (requerimientos e incidencias): mds@minsai.cl.
 - Temas de seguridad (eventos, debilidades de seguridad, incidentes, amenazas, riesgos): seguridadtic@minsai.cl.

Es obligatorio utilizar estos canales oficiales para garantizar una gestión oportuna, segura y eficiente de los incidentes reportados.

6.2 Gestión de Incidentes.

La institución llevará adelante la respuesta a incidentes a través de sus instancias técnicas y se coordinará con el equipo de respuesta a Incidentes y/o el Comité de Crisis, en la medida que el impacto de los incidentes afecte a los activos vitales de la organización.

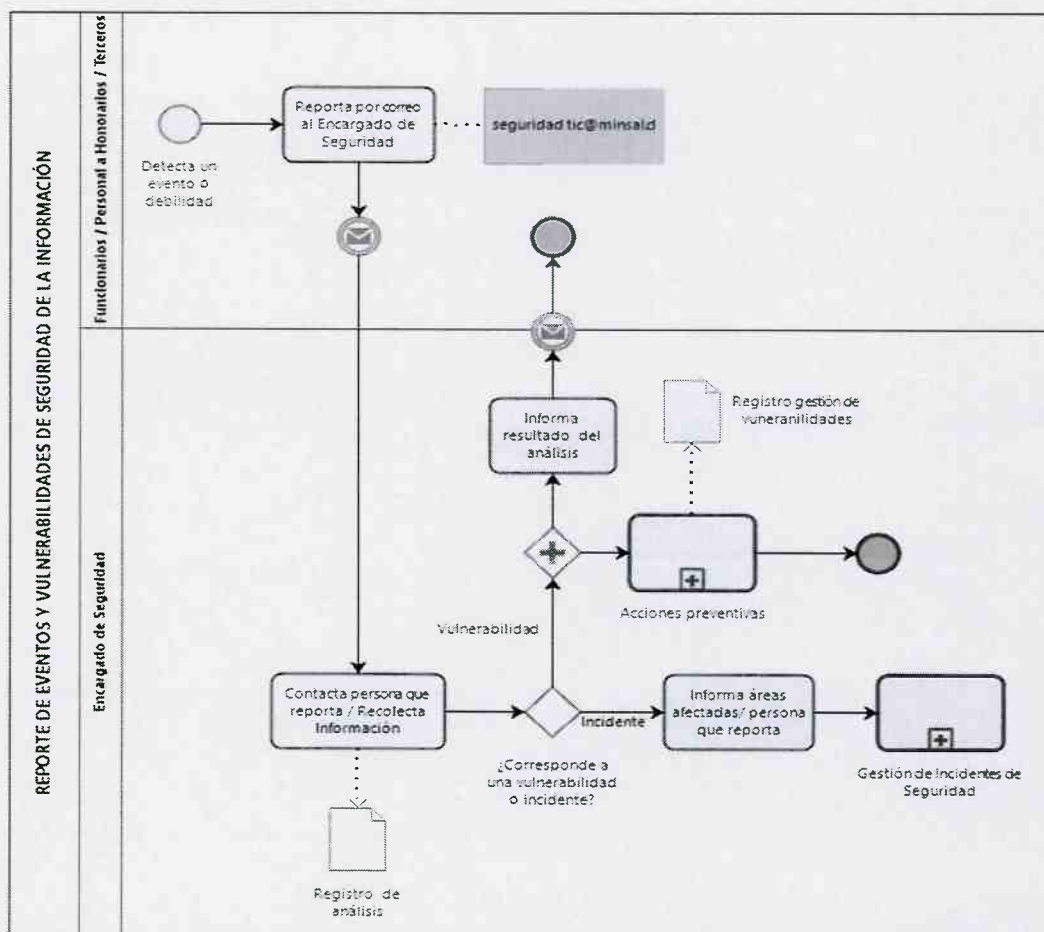
Los problemas relacionados a los incidentes de seguridad de la información dentro de la organización serán manejados por el Encargado de Seguridad de la Información y Ciberseguridad, el que se apoyará en el personal equipo de respuesta a Incidentes y/o el Comité de Crisis, con atención al resguardo de los principios de la Política General y las leyes vigentes. A su vez, el Encargado de Seguridad de la información y Ciberseguridad mantendrá los contactos correspondientes con las autoridades, grupos de interés externos o foros que manejen los problemas relacionados con los incidentes de seguridad de la información.

Cabe destacar que en la medida que los incidentes hayan sido judicializados, se requerirán de especiales cuidados, en orden a convocar a los expertos policiales para que accedan a la información necesaria para la investigación.



6.3 Reporte de eventos y debilidades en la Seguridad de la Información.

6.3.1 Flujo de la notificación.



Todo el personal de ambas Subsecretarías, en coordinación con su jefatura, es responsable de notificar cualquier tipo de evento que pueda afectar el funcionamiento normal del Sistema de Seguridad de la Información de la Institución.

Cada evento o incidente de relevancia se consignará en el sistema de tickets dispuesto por Minsal como herramienta central de registro y gestión de los incidentes, con objetivo central de concentrador y notificador de éstos, y, en consecuencia, disponer de un registro central de los incidentes.

En la herramienta centralizada de reporte y notificación de incidentes quedarán registradas también las actividades de administración de incidentes para poder evaluar los procesos involucrados (mejora continua) incorporando a ella aprendizajes obtenidos ante errores y/o aciertos de los planes de acción ejecutados.

Esta función es importante para la institución, pues en la medida que los funcionarios están alertas a estos detalles se maximiza la vigilancia y resguardo de los activos institucionales.

En este sentido todos los funcionarios deberán siempre estar alertas tanto a los temas de respeto a las políticas de seguridad de la información como a señales que parezcan extrañas o poco habituales, teniendo en consideración que cada uno de ellos puede ser blanco u objetivo de un ataque cibernético mediante el cual se puede acceder a información personal o institucional relevante, entre la que destaca en primera instancia:

Credenciales o contraseñas.

- Direcciones de correo electrónico.
- Perfiles de usuario o gustos personales de compras y/o navegación web.
- Información confidencial (documentos sensibles institucionales, tarjetas de crédito, entre otros).
- Recursos del sistema (CPU, USB y disco externos), para almacenar malware o utilizar equipos institucionales sin autorización.

Según el impacto del evento, el Encargado de Seguridad de la Información debe contactar a la persona que reporta y Jefatura del área relevante en un plazo no superior a 24 h, para recolectar toda la información necesaria para el análisis del evento, registrando todos los antecedentes.

Hecha la recolección de información sobre el incidente, el Encargado de Seguridad de la Información y Ciberseguridad debe analizar los antecedentes. El resultado de dicho análisis puede tener las siguientes opciones:

- a) **El evento no corresponde a una amenaza**: se cierra el registro de eventos, informando a la persona que reportó.
- b) **El evento corresponde a una vulnerabilidad**: se gestiona las actividades de mitigación (con los dueños de los activos comprometidos, el área o unidad de competencia y/o Comité de Seguridad), dejando registro de la gestión de la vulnerabilidad.
- c) **El evento ocurrió y debe ser gestionado como incidente**: se activa el proceso de Gestión de Incidentes de Seguridad.

Identificar Equipos/ Áreas Resolutoras por tipo de Incidentes.

Se deben asociar Equipos particulares o Áreas generales, como resolutores para abordar incidentes según su naturaleza, lo que debe quedar documentado para servir de guía de asignación de los incidentes una vez declarados.



PROCEDIMIENTO DE GESTIÓN DE INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN

Sistema de Gestión de Seguridad de la Información – Nivel Central

MINISTERIO DE SALUD

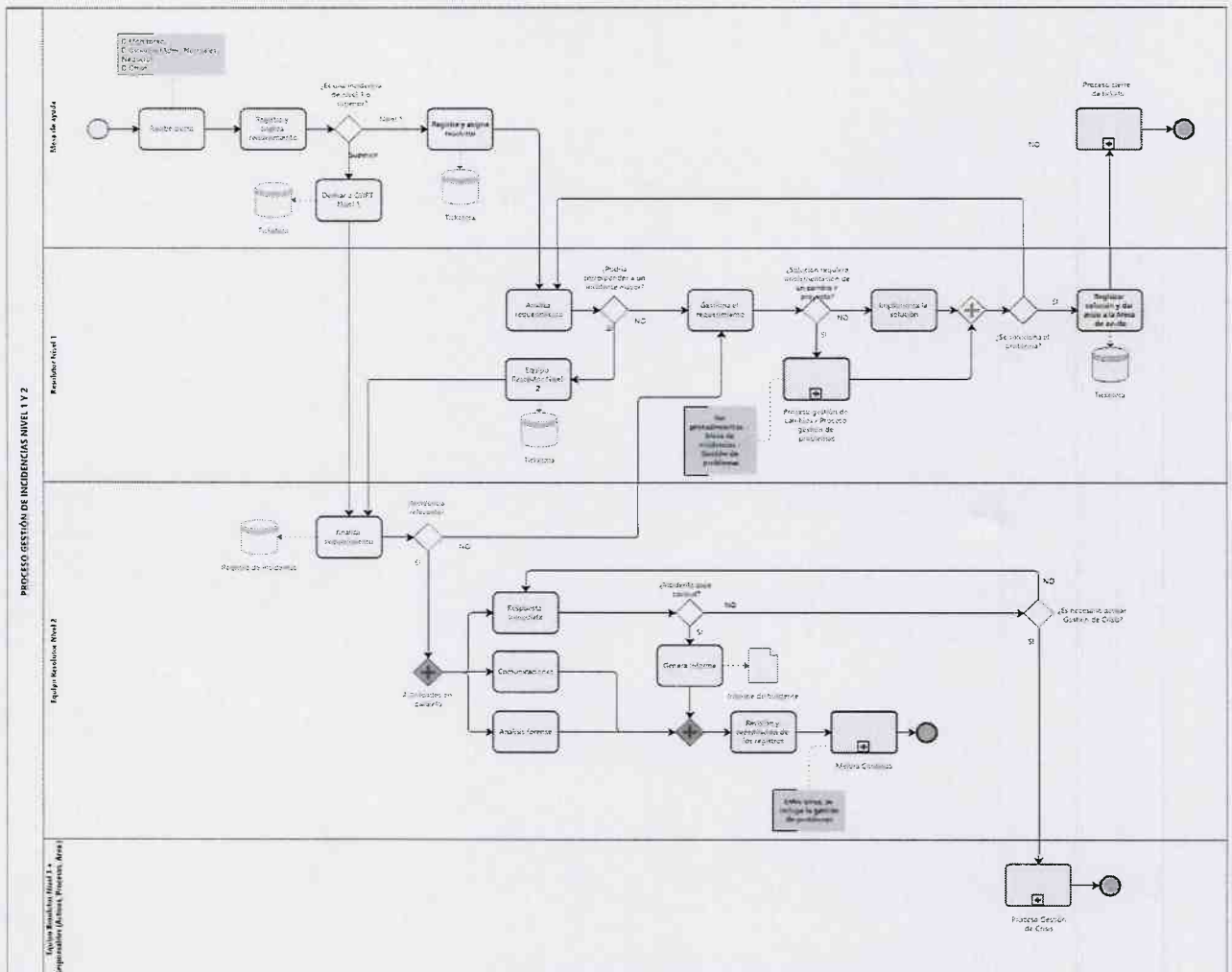
ID: PROS - NC- 07

Versión: 7

Página 13 de 28

TLP: BLANCO

6.4.2 Flujo resolución de incidencias Nivel 1 y Nivel 2



6.4.3 Registro y Clasificación del Incidente.

• Registro:

- ✓ La Mesa de ayuda, Resolutor Nivel 1 y el Encargado de Seguridad de la Información debe registrar el Incidente, según corresponda.

• Clasificación:

- ✓ La Mesa de ayuda, Resolutor Nivel 1 y el Encargado de Seguridad de la Información, según corresponda, deben clasificar el incidente, de acuerdo con el origen, tipo y nivel de criticidad.



6.4.4 Tipo de Incidente.

Tipo	Descripción	Ejemplos
a) Informático	Todos aquellos incidentes que afecten las tecnologías de la información o continuidad de las operaciones	▪ Denegación de servicios computacionales ▪ Fallas del sistema de información ▪ Código malicioso ▪ Accesos no autorizados a los sistemas de información ▪ Infraestructura TIC
b) No informático	Todos aquellos incidentes no contemplados en el punto anterior	▪ Violaciones a la confidencialidad, integridad y disponibilidad (documento) ▪ Filtración de información reservada ▪ Incidentes provocados por la naturaleza ▪ Acceso físico no autorizado

En general dependiendo del tipo de incidente los responsables de ejecutar la respuesta inmediata serían:

Tipo de Activo involucrado en el incidente	Jefatura responsable de la respuesta inmediata
Base de datos	Departamento TIC
Equipos TIC	
Formulario	
Infraestructura TIC	
Sistema	
Software	Departamento donde se desarrolla el proceso
Documento	
Expediente	Departamento Administración y Servicios
Otros equipos	
Infraestructura física	Departamento de RRHH
Persona	

6.4.5 Nivel de criticidad.

Una vez que se recibe la información sobre las causas del incidente, identifica alternativas de solución y, en caso de que la solución implique costos, se debe cuantificarlos para gestionar su aprobación.

Asimismo, deberá registrarse la información recopilada (Anexo N°1), descripción, responsables, análisis de la ocurrencia del incidente, tiempo de respuesta y solución al incidente, finalmente cuantificar y monitorear el tipo, volumen y costo del incidente. En caso de que haya implicancias legales o de otro tipo, deberá poner antecedentes en conocimiento de la División Jurídica y jefe de servicio para acordar curso a seguir. Toda respuesta a eventos y/o incidentes significativos deberá al menos incluir los siguientes aspectos para un mejor desempeño y atención del incidente:

- Recopilar la evidencia lo más pronto posible después de la verificación;
- Clasificar el Incidente de acuerdo con su tipo de taxonomía:
<https://www.enisa.europa.eu/publications/reference-incident-classification-taxonomy>
- Clasificar la severidad del incidente de acuerdo con la siguiente tabla:

Nº	Nivel	Descripción
1	Bajo	Impacto bajo sobre los activos: daño desde la amenaza no tiene consecuencias relevantes.
2	Medio	Impacto medio sobre los activos: daño desde la amenaza tiene consecuencias importantes.
3	Alto	Impacto alto sobre los activos: daño desde la amenaza tiene consecuencias graves sobre los activos.
4	Muy alto	Impacto muy alto: daño desde la amenaza tiene consecuencias catastróficas sobre los activos.
4	Crítico	Impacto crítico: daño desde la amenaza tiene consecuencias críticas y/o los procesos de negocio de la Institución.

- Efectuar escalamiento Nivel 2, según la pertinencia y relevancia del incidente;
- Asegurarse de que todas las actividades de respuesta se registren correctamente para el posterior análisis;



- Comunicación de la existencia del incidente de seguridad de la información o cualquier detalle pertinente a otras personas u organizaciones internas o externas que deban ser informadas o advertidas sobre estos incidentes;
- Manejar las debilidades de la seguridad de la información que causan o contribuyen al incidente;

6.4.6 Análisis y Evaluación de un Incidente de Seguridad Nivel 2 (Evaluación 2)

En el caso de que el incidente sea considerado por el evaluador nivel 2 como incidente relevante, este deberá realizar las siguientes actividades:

- Analizar toda la información relevante recopilada.
- Validar o reclasificar la severidad del incidente de acuerdo con la siguiente tabla:

Nº	Nivel	Descripción
1	Bajo	Impacto bajo sobre los activos: daño desde la amenaza no tiene consecuencias relevantes.
2	Medio	Impacto medio sobre los activos: daño desde la amenaza tiene consecuencias importantes.
3	Alto	Impacto alto sobre los activos: daño desde la amenaza tiene consecuencias graves sobre los activos.
4	Muy alto	Impacto muy alto: daño desde la amenaza tiene consecuencias catastróficas sobre los activos.
4	Critico	Impacto crítico: daño desde la amenaza tiene consecuencias críticas y/o los procesos de negocio de la institución.

- Gatillar Respuesta Inmediata.
- Iniciar cadena de custodia.
- Realizar análisis forenses de seguridad de la información, según sea necesario;
- Ejecutar Plan de Comunicaciones Interna.
- Documentar el incidente.
- Una vez que se ha manejado el incidente correctamente, se deberá cerrar y registrar formalmente.



Este nivel establecerá los procedimientos de respuesta específicos que permitan de una manera ordenada, estandarizada, segura y eficaz, responder a estas anomalías en la seguridad institucional.

Todos los incidentes de seguridad, incluyendo los falsos positivos, que hayan sido evaluados por el nivel 2 deberán ser revisados mediante análisis post-incidente, para identificar el origen de este, sus posibles implicancias, impacto en la organización, estudio de tendencias de incidentes analizados, así como también con el propósito de realizar una mejora continua sobre las acciones de control realizadas por esta unidad.

En caso de que el incidente de seguridad sea considerado relevante (Nivel de severidad 3 o superior) y no haya podido ser resuelto, es decir, que el incidente pese al plan de respuesta inmediata aplicado NO esté bajo control, deberá activarse el Proceso de Gestión de Crisis (**Ver procedimiento de Gestión de Crisis por Incidentes de Seguridad**).

6.4.7 Respuesta Inmediata.

El responsable del o los activos involucrados designados para la respuesta inmediata del incidente es o son responsables del desarrollo de las siguientes acciones inmediatas:

Actividad	Descripción
Contener el daño y minimizar el riesgo	Evitar que se propaguen los daños o efectos del incidente, coordinando las actividades necesarias para su disminución, probabilidad y consecuencia.
Reclasificar el incidente si fuera necesario	Reclasificar según punto 6.4.5
Protección de evidencias	Resguardar las evidencias recopiladas durante la gestión.
Notificación a los organismos externos	Cuando sea necesario notificar a organismos externos como por ejemplo (carabineros, PDI, Bomberos, etc.).
Recuperación de los sistemas	Contactar al administrador de el o los sistemas a fin de gestionar la recuperación de éstos.
Escalar con proveedores externos	Contactar a los proveedores expertos en el Activo Vital y en conjunto con ellos se deberá gatillar el plan de acción para resolver el incidente a la brevedad posible.



Actividad	Descripción
Compilación y organización de la documentación del incidente	Recopilar todos los antecedentes relacionados con el incidente.

En esta etapa el Encargado de Seguridad de la Información debe entregar lineamientos para la respuesta ante un incidente.

6.4.8 Activación de resolución de incidencias Nivel 3.

Si un incidente se agrava en su nivel de severidad o impacto en las personas o procesos, la propiedad y la infraestructura (Activos Ministeriales Vitales), y que además sea probable que continúe por un tiempo más prolongado de lo previsto, se entiende que este incidente pasa a ser una crisis y tratado de acuerdo con la siguiente organización.

6.5 Equipo de respuesta a incidentes y Comité de Crisis.

El equipo de respuesta a Incidentes y el Comité de Crisis serán los responsables de la gestión de los Incidentes dentro de la organización. Sus principales responsabilidades son: acelerar los procesos para la toma de decisiones en la resolución de incidentes, definir las prioridades, establecer la estrategia, asignar recursos y táctica a seguir.

Este es presidido por la figura máxima con capacidad de decisión (responsable máximo del organismo y/o representante del Gabinete de Ministro/a o Subsecretarios/as. Junto con ello debe tener representación y subrogante de a lo menos las siguientes áreas del Organización: Encargado de Seguridad de la Información y Ciberseguridad, Infraestructura Física, TIC (Operaciones, Infraestructura, Desarrollo, Explotación), Dueños de los Procesos, Recursos Humanos, Finanzas, Jurídica y Comunicaciones. La gestión de crisis no es algo exclusivo del equipo de seguridad o tecnología, sino que implica a toda la organización.

Será el presidente del comité el responsable de definir si se está ante una crisis o no, su nivel de criticidad, definición de medidas y asignación de responsabilidades, así como los distintos responsables en cada caso, desde lo operativo para la contención y resolución del incidente, hasta la coordinación y comunicación que velará por la imagen de la institución, estableciendo la política de información, con los comunicados más adecuados y canales oportunos.

A continuación, se presenta un cuadro resumen de los actores del Comité de Crisis y sus responsabilidades:



PROCEDIMIENTO DE GESTIÓN DE INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN

Sistema de Gestión de Seguridad de la Información – Nivel Central

MINISTERIO DE SALUD

ID: PROS - NC- 07

Versión: 7

Página 19 de 28

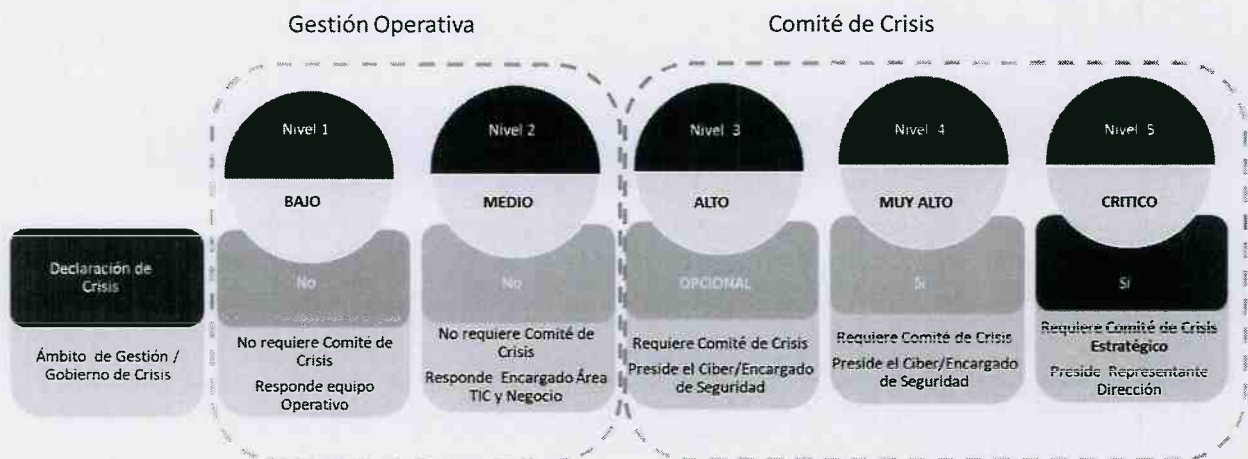
TLP: BLANCO

Representante	Responsabilidades
CEO / Representante Dirección General / Presidente	▪ Inicia la gestión de crisis y preside el comité de crisis. ▪ Delega responsabilidades. ▪ Se mantiene permanentemente informado. ▪ Actúa como portavoz si las circunstancias lo exigen.
Encargado de Ciber/Seguridad de la Información	▪ Es el primero en conocer el incidente y debe determinar nivel de criticidad (Impacto y Urgencia), si es preciso trasladarlo o no al comité de Crisis. ▪ Notifica al CSIRT de referencia. ▪ Determina cuáles son las primeras acciones operativas para su contención.
TIC	▪ Gestiona la continuidad de los servicios, utilizando según sea el caso, los respaldos o sitios de contingencia para los servicios críticos. ▪ Revisa el entorno común de todas las aplicaciones (comunicaciones, firewall, DNS, etc.), así como los específicos de cada aplicación. ▪ Gestionará de forma rápida servidores virtuales en caso de ser necesario. ▪ Activar Política de copias de seguridad.
PMO o Encargado del Proyecto	▪ Coordinar con los proveedores todas las acciones de contención, erradicación y cierre de los incidentes.
Jurídica	▪ Determina las responsabilidades legales directas provocadas por el incidente. ▪ Da seguimiento a las acciones a seguir de acuerdo a la leyes y normas aplicables. ▪ Orienta sobre todos los asuntos legales.
Comunicaciones	▪ Integra el Comité de Crisis y adopta el Manual de comunicaciones de crisis previamente elaborado. ▪ Decide cuáles son los mensajes clave, el formato y canal más adecuado, en función de los grupos de interés. ▪ Activa el seguimiento y percusión de la crisis en los diferentes medios de comunicación y redes sociales. ▪ Mantiene contacto con los medios de comunicación.
Administración y Finanzas	▪ Analiza los recursos necesarios para la resolución de la crisis. ▪ Recopila información, evalúa los hechos y plantea opciones. ▪ Mantiene comunicación con las compañías aseguradoras (si aplica).



Representante	Responsabilidades
Infraestructura Física	
Recursos Humanos	- Portavoz ante los funcionarios y en caso de ser aplicable, los representantes. - Gestiona las acciones operativas en caso de incidentes relacionados con personas. - Comunica, llegado el caso, con los afectados y facilita información o asistencia básica (por ejemplo, en caso de una lesión de un funcionario). - Evalúa el ánimo de los funcionarios y recomienda acciones para evitar decaimiento o una evolución no prevista.

6.6 Declaración del Nivel de crisis y equipo responsable según el nivel de criticidad (Impacto y Urgencia):



Ante incidentes con peligrosidad baja y media no deberían requerir la convocatoria de un Comité de Crisis, porque no se encuentra ante una situación que se pueda definir como tal.

Bajo la responsabilidad de directa del Encargado de Ciberseguridad, los equipos técnicos tienen el conocimiento para solucionar el problema en el nivel operativo.

En función del **nivel del incidente** actuarán distintos niveles o actores del Comité de crisis y procedimientos a seguir:

Atributo	Nivel de criticidad				
	Bajo	Medio	Alto	Muy Alto	Crítico
Declaración de Crisis	NO	NO	OPCIONAL	SI	SI
Nivel	1	2	3	4	5
Ámbito de Gestión /Gobierno de crisis	No requiere comité de crisis	No requiere Comité de Crisis	Requiere Comité de Crisis	Requiere Comité de Crisis	Requiere Comité de Crisis Estratégico
	Responde equipo Operativo	Responde Encargado Área TIC y Negocio	Preside el Encargado de Seguridad /Ciber	Preside el Encargado de Seguridad / Ciber	Preside Representante Dirección
Procedimiento	PROCEDIMIENTO GESTIÓN DE INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN		PROCEDIMIENTO GESTIÓN DE CRISIS		

6.7 Proceso Disciplinario.

Si el incidente es de mayor gravedad o se sospecha la comisión de algún delito, el Comité de Seguridad de la Información, asesorándose por el integrante de la División jurídica designado para las materias de Seguridad de Información, informará al Jefe Superior del Servicio y, de precisarse, a carabineros, bomberos, ambulancias, Ministerio Público, etc.

En el caso que existan eventuales responsabilidades administrativas, y dependiendo de la gravedad del incidente, el Comité de Seguridad de la Información solicitará a quien corresponda la instrucción de un procedimiento disciplinario para la investigación de las eventuales responsabilidades en los términos previstos en el Estatuto Administrativo.

Cuando el incidente involucre a personal contratado a honorarios o terceros, se evaluará solicitar el término anticipado del contrato o, en caso de que exista, la aplicación de la sanción que establezca el propio contrato, Política General de Seguridad de la Información u otras políticas ministeriales para el incidente detectado.



6.8 Continuidad de la Seguridad de la Información.

En caso de que el incidente no pueda ser controlado y ponga en riesgo las operaciones y entrega de productos y servicios del Ministerio, el Comité de Seguridad de la Información, evaluará la activación de los procesos de continuidad del negocio (Ver procedimiento de Gestión de Crisis por Incidentes de Seguridad, Política de Seguridad para la Continuidad).

6.9 Recolección de evidencia.

La recolección de la evidencia es responsabilidad del responsable del activo involucrado, designado para la resolución del incidente, la que debe ser reportada al Encargado de Seguridad para su revisión, ésta debe ser clara y suficiente. Para ello se deberá:

- Para los documentos en papel:
 - ✓ Se debe levantar inventario de los documentos.
 - ✓ El original es incluido en la cadena de custodia, y se guarda de manera segura con un registro del individuo que encontró el documento, dónde y cuándo fue encontrado el documento, y quién fue testigo del descubrimiento. En cualquier investigación se debe asegurar que los originales no son alterados.
 - ✓ Para los análisis se utilizarán copias numeradas de circulación controlada.
- Para la información sobre medios computacionales:
 - ✓ El proceso se inicia con la generación de una imagen espejo en presencia del ministro de fe de la institución. Se levanta inventario y se inicia la cadena de custodia.
 - ✓ El o los archivos originales y copias espejo se deben guardar de manera segura e intactos (se utilizan mecanismos de protección e incluso encriptación para que nadie adultere la evidencia).
 - ✓ En el caso de que no sea factible aislar y sacar de producción el original, la copia 1 será considerada original a estos efectos, en la medida que se resguarde el procedimiento anterior.
 - ✓ Las imágenes o copias espejo (dependiendo de los requisitos aplicables) de cualquier medio removible, información en discos duros o en memorias, deben ser numeradas y retenidas para asegurar su disponibilidad.
 - ✓ De todas las operaciones de análisis sobre estas copias se levantará acta identificando las personas que las manipulan, detalle de las operaciones realizadas y sus hallazgos o resultados.
 - ✓ El registro de todas las acciones durante el proceso de copiado se debería guardar y el proceso se debería efectuar ante testigos.



Cualquier trabajo forense se debe realizar sólo sobre copias del material de evidencia. Se debe supervisar y registrar cuándo y dónde fue ejecutado el proceso de copiado, quién realizó las actividades de copiado y qué herramientas y programas se han utilizado.

Si corresponde esta evidencia debe ser entregada al Comité de Seguridad de la Información para la evaluación de procesos disciplinarios.

6.10 Comunicación a los involucrados.

Una vez contenido el incidente, el Encargado de Seguridad de la Información debe informar a los involucrados en el Incidente.

6.11 Análisis de causa y cierre del incidente.

En esta etapa el Responsable del activo, designado para la resolución del incidente debe:

- Realizar un análisis de las causas del Incidente.
- Cuando el incidente no esté cerrado, seleccionar e implementar un plan de acción adecuado, además de definir el plazo para su implementación, dejando registro de las actividades. El seguimiento de este plan será responsabilidad del Encargado de Seguridad de la Información.
- Registrar el cierre del Incidente en un informe de cierre del incidente.

6.12 Aprender de los incidentes en la seguridad de la información

A lo menos cada seis meses el Encargado de Seguridad de la Información, debe revisar los incidentes de seguridad del período analizando:

- Posibles tendencias.
- Eficacia de los tratamientos implementados.
- Cuantificación de los tipos, volúmenes y costos de los incidentes de seguridad.
- Incidentes recurrentes o de alto impacto.
- Problemas subyacentes y medidas correctivas desarrolladas.
- Necesidades de mejorar o implementación de nuevos controles para limitar la frecuencia, daño y costo de futuras ocurrencias.

Con los antecedentes aportados por esta revisión, el Encargado de Seguridad de la Información debe proponer al Comité de Seguridad de la Información medidas que sean necesarias para que no vuelvan a ocurrir, además de detectar y promover los aprendizajes de cada uno de ellos.



7 PLAZOS DE NOTIFICACIÓN DE INCIDENTES DE SEGURIDAD.

De acuerdo con lo establecido en la Ley N° 21.663, Ley Marco de Ciberseguridad, se deben reportar al CSIRT Nacional los incidentes de ciberseguridad o ciberataques que puedan tener efectos significativos.

Todo incidente de seguridad debe ser notificado dentro de los siguientes plazos:

- Dentro de las 3 horas siguientes a conocer el incidente, se debe enviar una alerta temprana.
- Dentro de las 72 horas, se debe enviar una actualización con la evaluación inicial del incidente, su gravedad e impacto.
- Dentro de los 15 días corridos, se debe enviar un informe final sobre el incidente y las medidas adoptadas.

Nota: Se deberán informar a CSIRT Nacional aquellos Incidentes que provoquen la interrupción de la continuidad de un servicio esencial, afectar la integridad física o la salud de las personas, afectar sistemas informáticos que contengan datos personales.

El incumplimiento de estos plazos será considerado una falta grave, de conformidad con las normativas internas y los estándares legales, y podrá derivar en acciones disciplinarias o contractuales según corresponda.

8 REGISTROS:

- Registros cadena de custodia
- Registro de análisis de incidentes.
- Registro de gestión de vulnerabilidades.
- Acta de análisis de hallazgos
- Planilla registro de incidentes.
- Plan de acción.
- Informe de incidentes.
- Registro de cumplimiento del deber de notificar incidente
- Registro de cumplimiento de obligación de denuncia (si procede)
- Registro de Evidencias.

9 DIFUSION:

La comunicación del presente procedimiento se efectuará de manera que el contenido de la documentación sea accesible y comprensible para todos los usuarios, a lo menos se deberá hacer difusión mediante los siguientes canales:

- Publicación en la intranet de Minsal <http://isalud.minsal.cl/>
- Correo informativo.
- Publicación en sitio web Minsal http://www.minsal.cl/seguridad_de_la_informacion/



10 PERÍODO DE REVISIÓN.

El presente procedimiento deberá ser revisado cada dos años o cuando ocurran cambios significativos para garantizar que:

- Sigue siendo adecuado para su propósito y preciso.
- Refleja los cambios en las tecnologías.
- Está alineado con la legislación vigente, los estándares internacionales y las mejores prácticas.

11 EXCEPCIONES AL CUMPLIMIENTO DE LA POLÍTICA.

En situaciones excepcionales, el Jefe de Departamento TIC, el CISO o el Comité de Seguridad de la Información tendrán la facultad de evaluar y establecer condiciones específicas para la excepción al cumplimiento de las directrices establecidas en esta política, siempre que tales excepciones no infrinjan la legislación vigente ni comprometan la seguridad de la información.

Cada excepción deberá ser debidamente documentada, y se deberá iniciar un proceso de revisión de la política en el que se determinará si es necesario incorporar directrices adicionales o realizar modificaciones específicas.

12 CONTROL DE VERSIONES:

Versión	Fecha	Pág. o Sección modificada	Motivo del cambio
1	Diciembre 2012	N/A	Creación del documento
2	Octubre 2014	Puntos: 6.1, 6.2	Se modifican los flujos y responsabilidades. Se define como vía de contacto soporte@minsal.cl.
3	Octubre 2017	Todo el documento	Se actualiza: - Formato del procedimiento. - Diagramas de flujo. - Se reemplaza el uso de planilla de registro por el aplicativo de gestión de incidentes. Se modifican los registros del procedimiento.
4	Octubre 2019	Todo el documento	Se actualiza: Alcance del documento. Correo de contacto para informar incidentes.



PROCEDIMIENTO DE GESTIÓN DE INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN

Sistema de Gestión de Seguridad de la Información – Nivel Central

MINISTERIO DE SALUD

ID: PROS - NC- 07

Versión: 7

Página 26 de 28

TLP: BLANCO

Versión	Fecha	Pág. o Sección modificada	Motivo del cambio
			Flujos puntos 6.1 y 6.2. Punto 6.2.5. Punto 7. Punto 8.
5	Junio 2020	Todo el documento.	Flujos del procedimiento. Registros. Responsabilidades
6	Agosto 2021	Todo el documento.	Clasificación de los incidentes, según su nivel y responsables de la gestión.
7	Noviembre 2027	Pag. 2, 3, 4, 5, 6, 24, 25, 2 Alcance;3 Terminología;4 Normativa;5 Roles y Responsabilidades; 7 Plazos Notificación; 10 Periodo Revisión; 11 Excepciones,	Actualización Normativa ISO 27.001:2022 y Normativa de Gobierno sobre Ciberseguridad



13 ANEXOS

Anexo 1: Datos mínimos que deben ser registrados en el informe de incidentes.

Campo	Descripción	Campo	Descripción
Estado	Estado del Incidente (Abierto, Acciones Inmediatas, Acciones correctivas / Preventivas, Cerrado)	Responsable de la Acción Inmediata	Responsable de la Acción Inmediata
N°	Número de Evento / Incidente	Acción Inmediata	Descripción de las acciones inmediatas realizadas para contener el incidente.
Origen	Origen del Evento / Incidente	Fecha Acción inmediata	Fecha Acción inmediata
Fecha Reporte	Fecha Reporte	Hora Acción Inmediata	Hora Acción Inmediata
Hora Reporte	Hora Reporte	Se activa Continuidad del Negocio (S/N)	Indicar si se activa la continuidad del negocio
Identificación de quien reporta	Datos de la persona que reporta (nombre, cargo, organización, datos de contacto)	Registros y evidencia	Identificación de los registros y evidencias que respaldan el proceso disciplinario
Activos / Sistemas afectados	Descripción de los activos o Sistemas afectados (N° de serie, marca, tipo, soporte, etc.)	Análisis de causas	Registrar las causas de raíz que produjeron el Incidente
Corresponde a un Incidente o Debilidad	Indicar si corresponde a un Incidente o Debilidad	Acción Correctiva / Preventiva	Acciones correctivas o preventivas realizadas para eliminar las causas de raíz del incidente



PROCEDIMIENTO DE GESTIÓN DE INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN

Sistema de Gestión de Seguridad de la Información – Nivel Central

MINISTERIO DE SALUD

ID: PROS - NC- 07

Versión: 7

Página 28 de 28

TLP: BLANCO

Tipo de Incidente (I) Informático (NI) No Informático"	Indicar el Tipo de Incidente	Costos Asociados	Costos asociados al incidente
Nivel de criticidad	Registrar el nivel de criticidad en base a la urgencia e impacto	Respuesta y Cierre	Resumen de las actividades de cierre del incidente y conclusiones
Descripción del Incidente	Descripción del Incidente	Fecha Cierre	Fecha Cierre
Registro de Evidencias	Identificación de los registros y evidencias que respaldan las acciones realizadas		

